

Universidad Politécnica de San Luis Potosí.

“Ciencia, Tecnología y Cultura, al Servicio del Ser Humano”.

Actividad 4:

Materia:

Programación WAP

Profesor:

Servando López Contreras

Alumno y matricula:

Contreras Esparza Arturo 184565

Fecha: 08/31/2026



Contents

Introducción.	1
Objetivo.	1
Objetivos específicos.....	1
Pasos:	2
Controles de seguridad.	6
Recomendaciones para no caer en el phishing.	6
Conclusión:	6
Bibliografía:	7



Introducción.

El **phishing**, de acuerdo con Microsoft, es una práctica en la cual un atacante intenta ponerse en contacto con un usuario, haciéndose pasar por una empresa confiable o un conocido, con el objetivo de obtener información o hacer que la víctima interactúe con un enlace o un archivo malicioso.

Para llevar a cabo esta actividad, se hizo uso de una herramienta de código abierto llamada **SET (Social Engineering Toolkit)**. Este software fue creado con el propósito de realizar **pruebas de penetración enfocadas en la ingeniería social**.

Objetivo.

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante **Social-Engineer-Toolkit (SET)**, utilizando una **página web ficticia** para comprender el funcionamiento de una técnica de captura de información.

Objetivos específicos.

- i. **Configurar** un entorno básico de ingeniería social utilizando **SET**.
- ii. **Implementar** una **página web ficticia** mediante el módulo **Credential Harvester**.
- iii. **Analizar** el proceso mediante el cual la información es introducida en un formulario web, transmitida y registrada por un servidor.
- iv. Identificar indicadores técnicos y visuales que permitan reconocer una página fraudulenta.
- v. Proponer controles de seguridad orientados a reducir o prevenir el impacto de ataques phishing.



Pasos:

Debemos abrir la herramienta SET y posteriormente seguir los pasos indicados a continuación.

SET permite realizar ataques de ingeniería social, pruebas de penetración entre algunas otras cosas.

Para escoger lo que deseamos hacer deberemos introducir un numero mediante el teclado acorde al menú.

Las opciones para teclear son:

- i. Social-Engineering Attacks.
- ii. Weebsite Attack Vectors.
- iii. Credential Harvest Attack Method.
- iv. Custom import (Permite utilizar el archivo HTML previa mente preparado).

A partir de este punto **SET** nos guiara en el proceso.

- i. Lo primero que debemos hacer es introducir la ip a la cual los datos cosechados llegaran, por recomendación es la dirección ip de nuestro equipo.
- ii. Consecuentemente se nos solicitara la ruta, del sitio ficticio que construimos.
- iii. Inmediatamente se nos solicita la URL del sitio que clonamos, al ser esta una practica el sitio es falso y su dominio también.
- iv. El puerto 80 está activo y a la espera de cosechar, los datos se verán reflejados en la misma herramienta SET una vez un usuario interactúe con la página apócrifa, en este caso user = user y pass = 1234.



```
Shell No. 1
Session Actions Edit View Help

The Social-Engineer Toolkit is a product of TrustedSec.
Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> |
```

```
Shell No. 1
Session Actions Edit View Help

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2|
```



```
Shell No. 1
Session Actions Edit View Help
The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

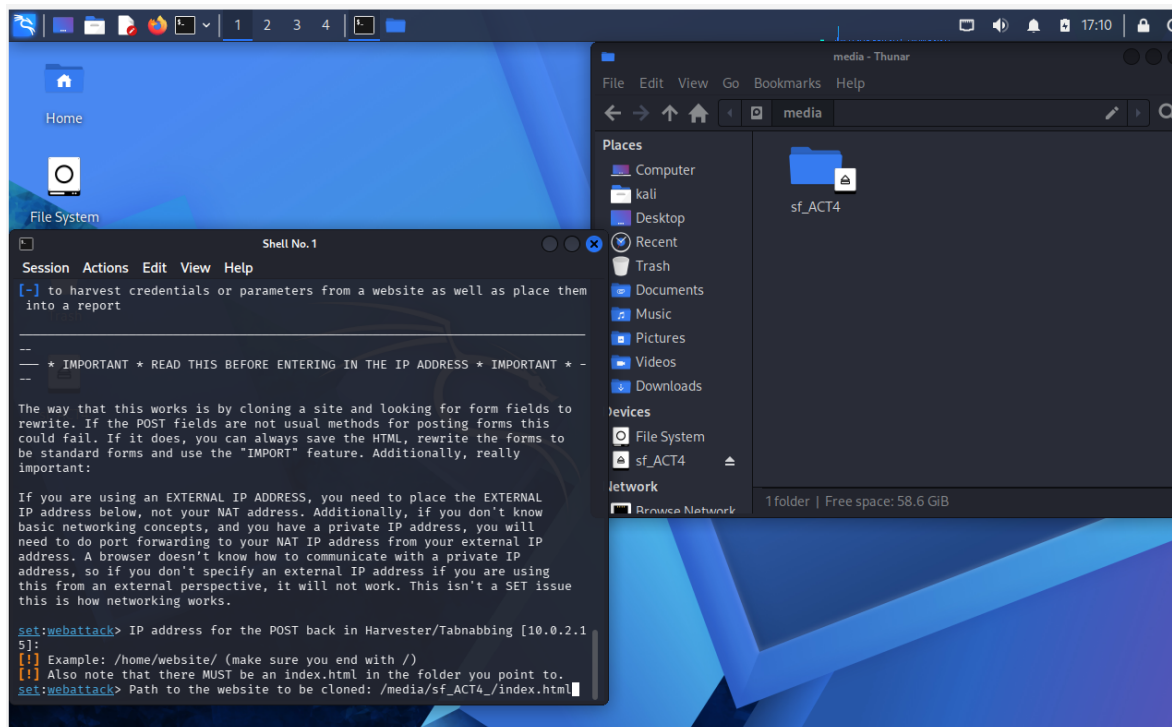
The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

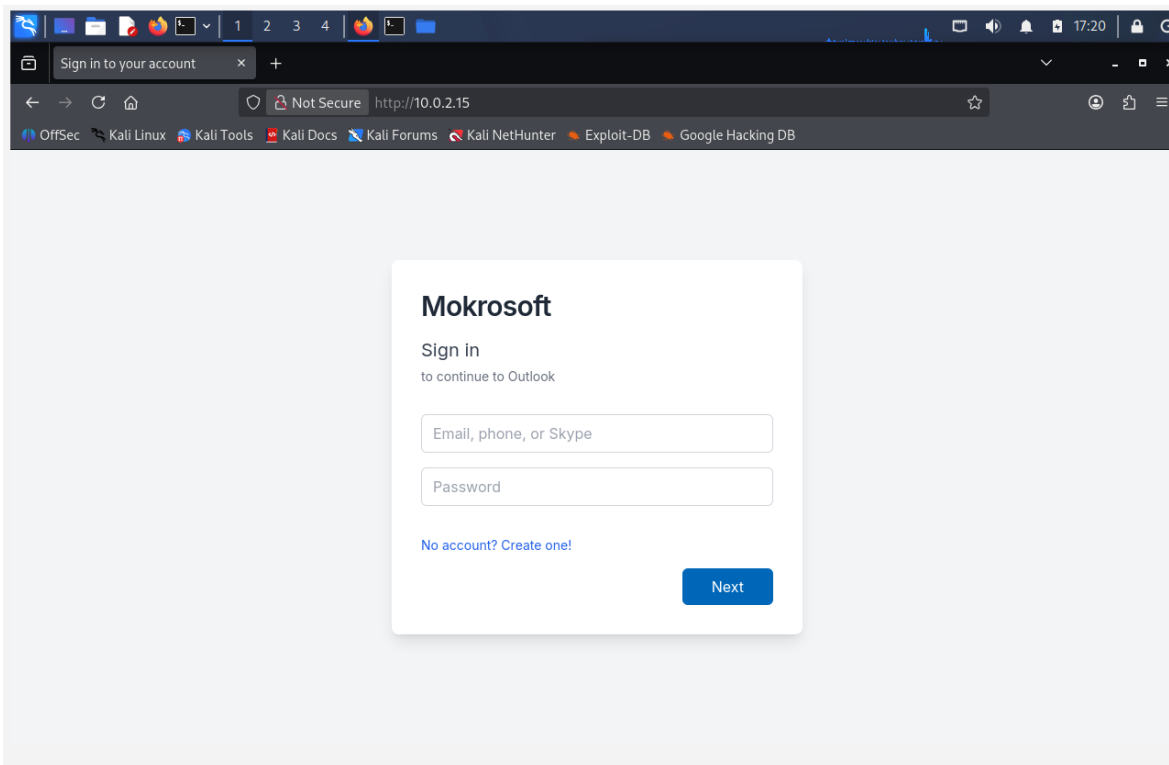
The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>
```





```
Shell No. 1
Session Actions Edit View Help
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.1
5]:
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /media/sf_ACT4/index.html
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: mokrosoft.com

The best way to use this attack is if username and password form fields are a
vailable. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:

10.0.2.15 - - [31/Aug/2026 17:20:15] "GET / HTTP/1.1" 200 -
10.0.2.15 - - [31/Aug/2026 17:20:15] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: usuario=user
PARAM: contrasena=1234
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```



Controles de seguridad.

Recomendaciones para evitar el phishing:

1: Autenticación en 2 factores:

Si el atacante obtiene correo y credenciales no podrá acceder sin el código secundario.

2: Filtros Antispam y Antiphishing:

Utiliza un software de seguridad que analice los correos entrantes. Bloquea de forma automática los mensajes sospechosos antes de que lleguen a la bandeja de entrada.

Recomendaciones para no caer en el phishing.

Algunas recomendaciones más:

Acorde a Microsoft estas son algunas de las practicas a tomar en cuenta para evitar caer en el phishing.

1: No hacer click en enlaces desconocidos o descargar archivos de remitentes desconocidos.

Este tipo de correos normalmente tienen cosas en común, una solicitud de urgencia, por ejemplo, su correo será deshabilitado si no da click al siguiente enlace.

2: Prestar atención a los nombres de los dominios.

3: Prestar atención al lenguaje y ortografía.

Conclusión:

Caer en un ataque como este es algo fácil cuando el pánico tiene lugar debido a falsas amenazas, estos sitios se caracterizan por ser copias idénticas de los sitios reales.

Ser victima de un ataque como este puede tener consecuencias devastadoras una persona o una empresa, por lo que es necesario aprender a reconocer sitios y correos apócrifos.



Bibliografía:

Microsoft. (s.f.). *Email authentication in cloud organizations*. Microsoft Learn. Recuperado el 30 de agosto de 2026, de [<https://learn.microsoft.com/en-us/defender-office-365/email-authentication-about>]

Microsoft. (s.f.). *Proteccion contra estafas y ataques en linea*. Microsoft Learn. Recuperado el 30 de agosto de 2026, de [<https://support.microsoft.com/es-es/security/protect-yourself-from-online-scams-and-attacks>]

